

MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

Calificación de las 25 Métricas FISMA FY2025 bajo los 9 Criterios PRAGMATIC

Kit GQM+PRAGMATIC — Documento (b) • Versión 1.0 • Abril 2026

"Evaluar métricas con metametrías es como usar un espejo para mirar otro espejo: en la profundidad de esa recursividad emerge, al fin, algo que se parece a la verdad."

— Inspirado en Brothby & Hinson, *PRAGMATIC Security Metrics* (2013)

GUÍA DE LECTURA DE LA MATRIZ

Los 9 Criterios PRAGMATIC (escala 0–10 por criterio, máximo 90 puntos)

#	Letra	Criterio	¿Qué evalúa?	Puntuación 0	Puntuación 10
1	P	Predictive (Predictivo)	¿Anticipa problemas futuros?	No predice nada	Predice con alta fiabilidad
2	R	Relevant (Relevante)	¿Importa a quienes deciden?	Nadie la usa	Crítica para el negocio
3	A	Actionable (Accionable)	¿Provoca acciones concretas?	No sugiere ninguna acción	Genera acción inmediata clara
4	G	Genuine (Genuino)	¿Mide lo que dice medir?	Proxy muy alejado del objeto	Medición directa del objeto
5	M	Meaningful (Significativo)	¿La entiende la audiencia?	Incomprensible sin traducción	Autoexplicativa para la dirección
6	A	Accurate (Preciso)	¿Datos suficientemente exactos?	Error de medición inaceptable	Alta precisión y fiabilidad
7	T	Timely (Oportuno)	¿Disponible cuando se necesita?	Siempre tarde o caducada	Tiempo real o muy próximo
8	I	Independent (Independiente)	¿Libre de manipulación?	Totalmente manipulable	Fuente externa verificada
9	C	Cheap (Rentable)	¿Coste razonable de obtener?	Prohibitivamente costosa	Obtenida de infraestructura existente

Escala de calificación total

Score /90	★	Calificación
81-90	★★★★★	Excelente — métrica de referencia
71-80	★★★★☆	Muy buena — implementación directa
61-70	★★★☆☆	Buena — mejoras menores recomendadas
51-60	★★☆☆☆	Aceptable — revisar criterios débiles
≤ 50	★☆☆☆☆	Débil/Inadecuada — rediseñar

MATRIZ PRINCIPAL: 25 MÉTRICAS × 9 CRITERIOS

(P=Predictivo, R=Relevante, A=Accionable, G=Genuino, M=Significativo, Ac=Preciso, T=Oportuno, I=Independiente, C=Rentable)

ID Métrica	No mbr e de la Métrica	Do mini o	Fun ción	P	R	A	G	M	Ac	T	I	C	TOT AL	★
Gov -1	Cyb erse curi ty Gov ern anc e Pro gra m	Gov ern anc e	GOV ERN	7	9	8	7	9	7	8	7	8	70	★ ★ ★ ★ ☆
Gov -2	Lea ders hip Acc oun tabi lity	Gov ern anc e	GOV ERN	6	9	8	6	9	6	7	7	8	66	★ ★ ★ ☆ ☆
Gov -3	Risk Tol eranc e Stat eme nt	Gov ern anc e	GOV ERN	7	8	7	7	8	7	6	8	9	67	★ ★ ★ ☆ ☆
SCR M-1	C- SCR M Plan and Poli cy	C- SCR M	GOV ERN	6	8	7	6	7	6	7	8	7	62	★ ★ ★ ☆ ☆
SCR M-2	Sup plie r Risk Ide ntifi cati on	C- SCR M	GOV ERN	7	8	8	6	7	7	6	7	6	62	★ ★ ★ ☆ ☆

SCR M-3	Sup plie r Risk Res pon se	C- SCR M	GOV ERN	7	9	8	7	7	7	6	7	7	65	★ ★ ★ ☆ ☆
RA- 1	Asse t Inve ntori y	Risk & Asse ts	IDE NTI FY	7	9	8	7	8	8	7	7	7	68	★ ★ ★ ☆ ☆
RA- 2	Syst em Cate gori zati on	Risk & Asse ts	IDE NTI FY	7	9	8	8	8	8	7	8	7	70	★ ★ ★ ★ ☆
RA- 3	Risk Asse ssm ent	Risk & Asse ts	IDE NTI FY	8	9	8	8	8	7	5	7	5	65	★ ★ ★ ☆ ☆
CM- 1	Con figu rati on Bas elin es	Con fig. Mg mt	PRO TEC T	7	9	9	7	8	8	7	7	7	69	★ ★ ★ ☆ ☆
CM- 2	Patc h Ma nag eme nt (Cri tical CVE)	Con fig. Mg mt	PRO TEC T	9	9	9	9	8	9	8	8	7	76	★ ★ ★ ★ ☆

CM-3	Vulnerability Scanning Coverage	Config. Mgmt	PROTECT	8	9	9	8	8	8	8	7	7	72	★ ★ ★ ★ ☆
IDA M-1	MFA Implementation	IDAM	PROTECT	8	9	9	9	9	9	8	8	8	77	★ ★ ★ ★ ☆
IDA M-2	Access Reviews / Least Privilege	IDAM	PROTECT	7	9	8	8	8	7	7	7	6	67	★ ★ ★ ☆ ☆
IDA M-3	Privileged Account Management	IDAM	PROTECT	8	9	9	7	8	8	8	8	6	71	★ ★ ★ ★ ☆
ZTA-S1	Zero Trust Data Management	Zero Trust	PROTECT	7	8	7	6	6	6	7	7	5	59	★ ★ ★ ☆ ☆ ☆

ZTA-S2	Zero Trust Asset Integrity	Zero Trust	DETECT	7	8	7	6	6	6	7	7	5	59	★ ★ ☆ ☆ ☆
DP-1	Data Classification & Inventory	Data Protection	PROTECT	6	8	7	6	7	7	6	7	6	60	★ ★ ☆ ☆ ☆
DP-2	Encryption Coverage	Data Protection	PROTECT	7	9	8	8	8	8	7	7	7	69	★ ★ ★ ☆ ☆
DP-3	DPI Completion Rate	Data Protection	PROTECT	6	8	8	7	7	7	5	8	6	62	★ ★ ★ ☆ ☆
ST-1	Security Awareness Training	Training	PROTECT	5	8	7	5	8	7	7	7	7	61	★ ★ ★ ☆ ☆
ST-2	Phishing Simulation Click Rate	Training	PROTECT	8	8	8	8	8	8	7	6	7	68	★ ★ ★ ☆ ☆

ISC M-1	SIE M Cov erag e & Log Rete ntio n	ISC M	DET ECT	7	9	8	8	7	8	8	8	6	69	★ ★ ★ ☆ ☆
ISC M-2	EDR / XDR Cov erag e	ISC M	DET ECT	8	9	9	9	8	9	8	8	7	75	★ ★ ★ ★ ☆
ISC M-3	Mea n Tim e to Dete ct (MT TD)	ISC M	DET ECT	9	9	9	8	9	7	7	8	7	73	★ ★ ★ ★ ☆
ISC M-4	CTI Con sum ptio n & Inte grat ion	ISC M	DET ECT	7	7	7	6	6	6	6	6	5	56	★ ★ ☆ ☆ ☆
IR-1	Incident Res pon se Plan	Incident Res p.	RES PON D	6	9	8	6	8	7	8	7	8	67	★ ★ ★ ☆ ☆
IR-2	IR Test ing Freq uen cy	Incident Res p.	RES PON D	7	8	8	7	7	7	7	7	7	65	★ ★ ★ ☆ ☆

IR-3	MT TC (Me an Tim e to Con tain)	Inci dent Res p.	RES PON D	9	9	9	8	9	7	7	8	6	72	★ ★ ★ ★ ☆
CP-1	Con ting enc y Plan Doc ume ntat ion	Con ting enc y	REC OVE R	6	9	7	6	8	7	7	7	7	64	★ ★ ★ ☆ ☆
CP-2	Con ting enc y Plan Test ing	Con ting enc y	REC OVE R	7	9	8	7	8	7	7	7	5	65	★ ★ ★ ☆ ☆

ANÁLISIS POR CRITERIO PRAGMATIC

Criterio P — Predictivo: ¿Qué métricas mejor anticipan problemas futuros?

Rank	Métrica	Score P	Justificación
	CM-2 (Patch MTTP)	9/10	Alta correlación empírica con incidentes explotados por CVE conocidos
	IR-3 (MTTC)	9/10	MTTC alto predice mayor impacto en incidentes futuros
	ISCM-3 (MTTD)	9/10	Tiempo de detección lento predice mayor dwell time y daño
	ST-2 (Phishing click rate)	8/10	Click rate alto predice mayor éxito de ataques de ingeniería social
	ST-1 (Training completion)	5/10	Completar formación no predice cambio de comportamiento real
	Gov-2 (Leadership accountability)	6/10	Difícil predecir incidentes desde métricas de gobernanza

Recomendación: Priorizar las métricas de resultado (MTTD, MTTC, click rate) sobre las métricas de proceso (formación completada, planes documentados) cuando el objetivo es predicción.

Criterio R — Relevante: ¿Qué métricas son más relevantes para las AAPP españolas?

Todas las métricas con $R \geq 9$ son **obligatorias** bajo al menos uno de los marcos normativos aplicables:

Métrica	R	Obligatoriedad normativa
Gov-1, Gov-2	9	ENS Art. 13; NIS2 Art. 20
RA-2 (Categorización)	9	ENS Arts. 40-44 (obligatorio)
CM-1, CM-2, CM-3	9	ENS op.exp.3-4; NIS2 Art. 21.2.g
IDAM-1 (MFA)	9	NIS2 Art. 21.2.j (obligatorio explícitamente)
DP-2 (Cifrado)	9	NIS2 Art. 21.2.h; RGPD
CP-1, CP-2	9	ENS Art. 26; NIS2 Art. 21.2.c
IR-1, IR-3	9	ENS Art. 25; NIS2 Art. 23
ISCM-2 (EDR)	9	ENS mp.eq.3; NIS2 Art. 21.2.b

Criterio A — Accionable: ¿Qué acción concreta provoca un valor bajo?

Métrica	Valor bajo indica	Acción inmediata recomendada
IDAM-1 (MFA)	< 90% usuarios con MFA	Desplegar MFA universal; bloquear acceso sin MFA a sistemas críticos
CM-2 (Patch MTTP)	> 15 días para CVE críticos	Proceso de parcheo de emergencia; suscripción CISA KEV
ISCM-2 (EDR)	< 95% endpoints cubiertos	Inventario de endpoints sin EDR; despliegue prioritario
IR-3 (MTTC)	> 4 horas contención	Revisión del playbook de respuesta; automatización SOAR
ST-2 (Phishing click)	> 10% click rate	Campaña intensiva de concienciación; simulacros mensuales
CP-2 (Plan testing)	Sin prueba en > 12 meses	Programar ejercicio de continuidad inmediato

Métricas menos accionables (requieren deliberación estratégica):

- Gov-2 (Accountability directiva): la acción es lenta y depende de cultura organizacional
- ZTA-S1/S2: la acción requiere roadmap a 2-3 años
- ISCM-4 (CTI): requiere acuerdos y capacidades especializadas

Criterio G — Genuino: Análisis de Validez de Constructo

El criterio Genuino identifica el riesgo de **métricas proxy** — aquellas que miden algo relacionado pero no el fenómeno de interés real.

Métricas genuinas (G ≥ 8): miden directamente el objeto:

Métrica	G	¿Por qué es genuina?
CM-2 (Patch MTTP)	9	El tiempo de parche ES el riesgo de explotación; correlación directa
IDAM-1 (MFA)	9	La presencia/ausencia de MFA ES la medida del control; sin ambigüedad
ISCM-2 (EDR coverage)	9	La cobertura EDR ES el estado del control de detección
RA-2 (Categorización)	8	La categorización correcta ES el fundamento de la proporcionalidad
DP-2 (Cifrado)	8	El % cifrado ES la medida del control de confidencialidad

Métricas con riesgo de ser proxy ($G \leq 6$): requieren interpretación cuidadosa:

Métrica	G	Riesgo de proxy
Gov-2 (Leadership accountability)	6	Reuniones y documentos $\neq$ cultura real de seguridad
ST-1 (Training completion)	5	Completar curso $\neq$ cambio de comportamiento
SCRM-1 (C-SCRM Plan)	6	Tener plan $\neq$ gestionar realmente la cadena de suministro
CP-1 (Plan documentation)	6	Plan documentado $\neq$ recuperación real posible
ZTA-S1/S2	6	Nivel ZTMM $\neq$ efectividad real de controles ZTA

Criterio T — Oportuno: Frecuencia de Medición Recomendada

Frecuencia	Métricas	Justificación
Tiempo real / Continuo	ISCM-2 (EDR), ISCM-3 (MTTD), CM-3 (Vulnerability scan)	Amenazas activas; deterioro rápido
Diario / Semanal	CM-2 (Patch MTTP), IDAM-1 (MFA coverage)	Ventana de explotación estrecha
Mensual	ST-2 (Phishing click rate), IR-3 (MTTC), ISCM-1 (SIEM coverage)	Tendencias de comportamiento
Trimestral	Gov-1/2, IDAM-2 (Access reviews), SCRM-2	Revisión de gestión
Semestral	RA-1/3, DP-1/3, CP-2	Ciclos de planificación
Anual	RA-2 (Categorización), IR-1/2, CP-1, Gov-3, ST-1	Ciclos formales de revisión

Métricas con bajo score T (5-6): riesgo de información caducada al momento de usarse:

- RA-3 (Risk Assessment): T=5; un AR anual para sistemas en rápida evolución puede quedar obsoleto
- ISCM-4 (CTI): T=6; la inteligencia de amenazas debe ser casi en tiempo real
- DP-3 (DPIA): T=5; DPIAs tardan meses en completarse

Criterio I — Independiente: ¿Quién valida qué?

Máxima independencia ($I \geq 8$): validación por terceros o sistemas automatizados:

Métrica	I	Mecanismo de independencia
RA-2 (Categorización)	8	Validada por auditor ENS externo bienal
IDAM-1 (MFA)	8	Dato técnico obtenible de directorios sin intervención del medido
Gov-3 (Risk Tolerance)	8	Aprobación formal del órgano de gobierno registrada
ISCM-1 (SIEM logs)	8	Log inmutables del SIEM; difícilmente manipulables
DP-3 (DPIA)	8	Validación por DPO independiente y AEPD en supervisión

Riesgo de sesgo ($I \leq 7$): requieren procedimientos adicionales:

Métrica	I	Riesgo
ST-2 (Phishing click rate)	6	El proveedor de simulacros puede ajustar la dificultad para inflar resultados
Gov-2 (Accountability)	7	Documentación directiva puede ser generada retroactivamente
ISCM-4 (CTI)	6	La valoración de fuentes CTI es subjetiva
SCRM-2/3	7	El evaluador de proveedores puede tener incentivos para aprobar

Criterio C — Rentable: Coste Estimado de Recopilación

Coste	Métricas ($C \geq 8$)	Fuente de datos
Muy bajo	Gov-1, Gov-3, RA-2	Revisión documental; proceso existente
Bajo	CM-2, IDAM-1, IR-1	Herramientas de gestión de parches, directorio activo, ITSM
Medio	ISCM-1/2, DP-2, ST-1/2	SIEM, EDR, DLP existentes; requieren configuración
Alto	RA-3, DP-1, CP-2	Análisis de riesgos formal, taxonomía de datos, ejercicios continuidad
Muy alto	ZTA-S1/S2, ISCM-4, SCRM-3	Madurez ZTA requiere inversión; CTI y C-SCRM profundo son caros

Métricas con mejor ratio beneficio/coste ($C \geq 8$ Y score total ≥ 70):

- CM-2: $C=7$, total=76 — Invertir en automatización de parcheo es altamente rentable
- IDAM-1: $C=8$, total=77 — MFA: bajo coste relativo, altísimo impacto
- ISCM-2: $C=7$, total=75 — EDR: plataformas maduras y coste decreciente

RANKING GLOBAL POR SCORE PRAGMATIC

Top 10 Métricas FISMA FY2025 por Calidad PRAGMATIC

Rank	ID	Métrica	Score /90	★	Fortaleza principal	Debilidad principal
 1	IDAM-1	MFA Implementation	77	★★★★☆	Genuino + Accionable	Coste de despliegue a escala legacy
 2	CM-2	Patch MTTP Critical CVE	76	★★★★☆	Predictivo + Preciso	Complejidad en entornos OT/legacy
 3	ISCM-2	EDR/XDR Coverage	75	★★★★☆	Genuino + Accionable	Entornos IoT/OT no cubiertos
4	ISCM-3	Mean Time to Detect	73	★★★★☆	Predictivo + Significativo	Difícil medir sin incidente previo
5	CM-3	Vulnerability Scanning	72	★★★★☆	Accionable + Oportuno	Coste en parques heterogéneos
6	IR-3	MTTC (Mean Time Contain)	72	★★★★☆	Predictivo + Accionable	Requiere SOAR para ser barata
7	IDAM-3	PAM Coverage	71	★★★★☆	Accionable + Oportuno	PAM no usado activamente = proxy
8	Gov-1	Governance Program	70	★★★★☆	Relevante + Significativo	Genuinidad limitada
9	RA-2	System Categorization	70	★★★★☆	Genuino + Independiente	Actualización lenta
10	ISCM-1	SIEM Coverage	69	★★★☆☆	Relevante + Independiente	Coste de ingeniería de datos

Bottom 5 Métricas: Revisión Recomendada

Rank	ID	Métrica	Score /90	★	Principal debilidad	Mejora sugerida
↓	ZTA-S1	Zero Trust Data Mgmt	59	★★☆☆☆	Subjetividad nivel ZTMM	Añadir criterios objetivos por pilar
↓	ZTA-S2	Zero Trust Asset Integrity	59	★★☆☆☆	Misma debilidad ZTA-S1	Ibídem
↓	DP-1	Data Classification	60	★★☆☆☆	Proxy + coste alto	Automatizar con DLP/DSPM
↓	ISCM-4	CTI Consumption	56	★★☆☆☆	Precisión + coste	Objetivar: n° IOC's integrados/mes
↓	ST-1	Training Completion	61	★★★☆☆	Genuinidad muy baja	Complementar con ST-2 y prueba práctica

ANÁLISIS POR FUNCIÓN CSF 2.0

Función CSF 2.0	Nº Métricas	Score medio /90	Función más sólida	Principal debilidad de la función
GOVERN	6 (Gov-1/2/3, SCRM-1/2/3)	65.3	Relevancia (R=8.5)	Genuinidad (G=6.5) — riesgo de métricas formales vacías
IDENTIFY	3 (RA-1/2/3)	67.7	Relevancia y Accionabilidad	Oportuno (T=6.3) — procesos lentos
PROTECT	12 (CM-1/2/3, IDAM-1/2/3, ZTA-S1/S2, DP-1/2/3, ST-1/2)	67.8	Accionabilidad (A=8.1)	ZTA y DP-1 arrastran la media
DETECT	4 (ISCM-1/2/3/4)	68.3	Predictividad (P=7.75)	ISCM-4 (CTI) es la más débil
RESPOND	3 (IR-1/2/3)	68.0	Relevancia + Significatividad	Genuinidad IR-1 (plan ≠ capacidad)
RECOVER	2 (CP-1/2)	64.5	Relevancia (R=9)	Barato (C=6) — pruebas costosas y CP-1 Genuino bajo

RECOMENDACIONES DE MEJORA POR CRITERIO

Para mejorar el criterio G (Genuino) — el más débil del conjunto:

1. Complementar métricas de proceso con métricas de resultado: Cada métrica de existencia (plan documentado, formación completada) debe tener asociada al menos una métrica de resultado (MTTC, click rate, tiempo de parcheo).
2. Red-Team anual: Los resultados de Red Team ejercicios validan si las métricas de proceso reflejan capacidades reales.
3. Benchmarking externo: Comparar MTTC, MTTC y phishing click rate con datos ENISA/CCN-CERT para validar la escala de medición.

Para mejorar el criterio T (Oportuno) — segundo más débil:

4. Automatizar la recopilación: Las métricas de estado técnico (IDAM-1, CM-2, ISCM-2) deben obtenerse de APIs de las herramientas existentes, no de encuestas manuales.
5. Dashboard en tiempo real: Conectar SIEM, EDR, gestión de parches y directorio activo a un dashboard FISMA actualizado diariamente.
6. Alerta temprana: Configurar alertas automáticas cuando una métrica clave supera umbral (p.ej., CM-2 > 15 días para KEV).

Para mejorar el criterio C (Rentable) — especialmente en ZTA y C-SCRM:

7. Faseado de implementación: Empezar con las métricas de mayor ROI (IDAM-1, CM-2, ISCM-2) que tienen alto score total y bajo coste relativo.
8. Reutilizar infraestructura existente: Muchas métricas son obtenibles de herramientas que las AAPP ya tienen (Active Directory → IDAM-1; gestión de parches → CM-2; antivirus → ISCM-2).
9. Métricas ZTA y CTI: Implementar en fase 2 (año 2-3), una vez consolidadas las métricas core.

MAPA DE CALOR: CRITERIOS DÉBILES POR DOMINIO

(rojo = ≤ 6, ámbar = 7, verde = ≥ 8)

Domini o	P	R	A	G	M	Ac	T	I	C
Govern ance	7	9	7	6	9	7	7	7	8
C- SCRM	7	8	8	6	7	7	6	7	7
Risk & Assets	7	9	8	8	8	8	6	7	6
Config. Mgmt	8	9	9	8	8	8	8	7	7
IDAM / ZTA	7	9	8	7	7	7	7	7	6
Data Prot.	6	8	8	7	7	7	6	7	6
Trainin g	6	8	8	6	8	8	7	6	7
ISCM	8	9	8	7	7	7	7	7	6
Inciden t Resp.	7	9	9	7	8	7	7	7	7
Conting ency	7	9	8	6	8	7	7	7	6

Patrón sistémico identificado: Los criterios **G (Genuino)**, **T (Oportuno)** y **C (Rentable)** son los más débiles en todos los dominios. Esto refleja una tensión estructural inherente a la medición de seguridad: las métricas más genuinas (resultado real) son también las más caras y difíciles de obtener en tiempo real.

Kit GQM+PRAGMATIC FISMA 2025 — Matriz de Evaluación PRAGMATIC · Versión 1.0 · Abril 2026

Fuentes: Brothby & Hinson (2013) PRAGMATIC Security Metrics; FY2025 IG FISMA Metrics v2.0; NIST CSF 2.0; CISA CDM; CCN-STIC Series 800